DOCUMENTACION DE SISTEMA

RootCause Bitcoin Defense

16 · Glosario

Version analizada 0.3.0 · commit acdf4dd · generado el 2026-08-27
Documento 16 de la serie · fuente: docs/system-documentation/16-glossary.md

Contenido

1 · Conceptos del dominio Bitcoin
2 · Conceptos del sistema
3 · Clases y funciones que conviene conocer por su nombre
4 · Estados y enumeraciones
5 · Familias de reglas
6 · Siglas técnicas
7 · Términos del proyecto y de la familia RootCause
8 · Nombres que aparecen y conviene no confundir
9 · Frases del proyecto que resumen su criterio

Todo término que aparece en el código, en el panel o en esta documentación, explicado sin dar nada por sabido.

> `../GLOSARIO.md` cubre el vocabulario del dominio Bitcoin para el usuario final. Este glosario **añade los términos del sistema** —clases, conceptos internos, estados y siglas de ingeniería— y repite lo mínimo imprescindible del dominio para que se pueda leer solo.

---

1 · Conceptos del dominio Bitcoin

Término	Qué es
Semilla	El secreto del que se derivan todas las claves de un monedero. Normalmente se representa como 12 o 24 palabras. Quien la tiene, tiene el dinero
Entropía	La aleatoriedad con la que se generó una semilla. Si es insuficiente o predecible, la semilla se puede reconstruir sin robar nada
Procedencia de una clave	Con qué dispositivo, modelo, versión de firmware y método se creó una semilla. **Es el objeto central de este producto**
Firmware	El programa que corre dentro de una hardware wallet. Un defecto en él puede afectar a las semillas que generó
Huella (*fingerprint*)	Ocho caracteres hexadecimales que identifican una clave sin revelarla. Es lo que este sistema guarda en lugar de la clave
Firmante (*signer*)	Un dispositivo capaz de firmar. Una wallet single-sig tiene uno; una multisig, varios

Término	Qué es
Single-sig	Una sola firma basta para gastar. Simple y frágil: quien compromete esa clave se lleva todo
Multisig	Hacen falta varias firmas. Se escribe *M-de-N*: `2-de-3` significa dos firmas de tres firmantes posibles
Quorum	Cuántas firmas se necesitan (`required`) de cuántas hay (`total`)
N-de-N	Un quorum que exige **todas** las firmas. Parece más seguro y no lo es: perder una sola clave deja los fondos irrecuperables para siempre
Diversidad de fabricantes	Que los firmantes de un quorum sean de marcas distintas, para que un fallo de firmware no los afecte a todos
Watch-only	Un modo que observa sin poder gastar. **Este producto es watch-only por construcción**: no tiene código de firma
UTXO	Una porción de bitcoin no gastada. Migrar fondos significa mover los UTXO a una wallet nueva
PSBT	Transacción parcialmente firmada, el formato estándar para pasar una transacción entre dispositivos
`txid`	El identificador de una transacción, 64 caracteres hexadecimales
Mempool	La cola de transacciones pendientes de un nodo. Si se llena, las de menor tarifa se expulsan
IBD	*Initial Block Download*. El nodo aún está descargando y validando la cadena, así que su vista está incompleta
Peer	Otro nodo de la red al que el tuyo está conectado. Cero peers significa estar aislado
Regtest	Una red Bitcoin local de laboratorio, sin valor real. Sirve para ensayar incidentes
Descriptor	La descripción formal de cómo se derivan las direcciones de una wallet
Aviso (*advisory*)	Comunicación de un fabricante sobre un defecto de seguridad. Este sistema los cruza con el inventario

---

2 · Conceptos del sistema

Término	Qué es en este código
Hallazgo (*finding*)	Lo que produce una regla cuando su condición se cumple. Lleva siempre código, severidad, explicación, causa raíz, evidencia y remediación
Incidente	Un hallazgo **con historial**: cuándo apareció, cuándo se vio por última vez, si alguien lo reconoció y si se resolvió
Causa raíz (*rootCause*)	La afirmación causal del hallazgo: por qué el problema existe, no solo qué se observó. Es lo que da nombre a toda la familia RootCause
Evidencia	Los datos públicos que sostienen el hallazgo. Pasan por `redactForAudit` antes de escribirse
Remediación	Los pasos concretos, en orden de ejecución. Una alerta sin siguiente paso entrena a ignorar alertas
Postura de despliegue	El resultado de que la aplicación **se audite a sí misma**: cómo está configurada, dónde escucha, si cifra, si vigila

Término	Qué es en este código
Watchtower	El servicio opcional que consulta el nodo y reevalúa periódicamente. Apagado por defecto
Matriz de avisos	El contenido de `config/advisories.json`
Frescura de la inteligencia	Cuánto hace que se contrastó la matriz con las fuentes oficiales. **Su antigüedad es en sí misma un hallazgo**
Estado (*state*)	El objeto JSON único que contiene todo lo que el sistema sabe
Actor	La etiqueta que se atribuye a una acción en el registro de auditoría. **No es una identidad autenticada**
Aprobación	Un hash de transacción registrado de antemano. Un gasto que coincida no genera hallazgo
Cadena de auditoría	La lista de entradas encadenadas por hash
Cobertura declarada	Lo que una comprobación realmente miró. **Todo informe de este proyecto la declara**
Etapa omitida	Una comprobación que no pudo ejecutarse. **Nunca es un aprobado**
Puerta de calidad	Una comprobación de CI que bloquea el build
Invariante	Una propiedad que debe cumplirse siempre. Aquí se verifican **ejecutando la aplicación**, no leyéndola
Claim	Una promesa pública del producto. Cada una tiene un script que la comprueba
Solo-local	El claim de que la aplicación corre entera en la máquina del usuario, sin dependencias ni orígenes remotos
Fuente única	Un archivo del que se generan otros. Editar el generado rompe el build

3 · Clases y funciones que conviene conocer por su nombre

Nombre	Qué es
`DefenseService`	El orquestador. El **único** punto que escribe estado
`MemoryStore` / `EncryptedFileStore`	Las dos implementaciones de persistencia, con el mismo contrato
`BitcoinRpcClient`	El cliente RPC, incapaz por construcción de mover fondos
`Watchtower`	La vigilancia periódica
`SecretMaterialError`	El error que se lanza cuando entra material secreto. Produce un `422`
`assertNoSecretMaterial`	**La frontera que define el producto**
`redactForAudit`	Lo que impide que un secreto acabe escrito en el registro
`evaluateState`	Ejecuta las siete familias de reglas
`evaluatePosture`	Las ocho reglas sobre la propia instalación

Nombre	Qué es
`mergeIncidents`	Refunde hallazgos nuevos con el historial
`mutate`	La cola que serializa todas las escrituras
`findingId`	El hash determinista que permite reconocer un hallazgo entre análisis
`appendAuditEntry` / `verifyAuditChain`	Escribir y verificar la cadena
`loadConfig`	La lectura única y congelada del entorno
`buildRuntime`	El *composition root*: dónde se decide con qué piezas corre el sistema

---

4 · Estados y enumeraciones

4.1 · Estado de un incidente

Valor	Significado
`open`	Detectado y sin reconocer
`acknowledged`	Alguien lo vio. **Sigue activo y sigue contando en el riesgo**
`resolved`	La condición dejó de cumplirse. Volverá a `open` si reaparece

4.2 · Severidad

Valor	Peso	Cuándo
`critical`	100	Puede costar fondos hoy
`high`	75	Debilidad relevante que requiere corrección prioritaria
`medium`	45	Trazabilidad o controles incompletos
`low`	20	Exposición acotada
`info`	5	Informativo

4.3 · Nivel de riesgo agregado

Nivel	Puntuación
`critical`	≥ 85
`high`	≥ 65
`medium`	≥ 35
`low`	> 0
`clear`	0

4.4 · Estado de una wallet

Valor	Significado
`active`	En uso normal
`migration-required`	Debe migrarse
`quarantined`	En cuarentena
`retired`	Retirada de servicio

4.5 · Origen de la semilla

Valor	Significado
`device`	La generó el propio dispositivo
`dice`	Se generó con una fuente independiente, como dados
`external`	Se importó de otro sitio
`unknown`	**No se sabe.** Dispara `BTC-KEY-003`

4.6 · Estado de una etapa de auditoría

Icono	Valor	Significado
[OK]	`ok`	La comprobación se hizo y salió bien
[ATENCION]	`atencion`	Deuda declarada, no rotura
[FALLO]	`fallo`	Una promesa del producto dejó de cumplirse
[NO COMPROBADO]	`omitida`	**No comprobada.** Nunca es un aprobado

---

5 · Familias de reglas

Prefijo	Qué mira
`BTC-KEY`	De dónde vino la clave y si se puede demostrar
`BTC-CUSTODY`	Si la arquitectura contiene el compromiso de un firmante
`BTC-TX`	Movimientos que no coinciden con ninguna aprobación registrada
`BTC-NODE`	Si la aplicación está viendo la realidad o está ciega
`BTC-PRIVACY`	La superficie de una wallet incluye a quien la usa
`BTC-INTEL`	Un verde sobre avisos sin revisar es una tranquilidad falsa
`BTC-OPSEC`	La herramienta con la que miras tus claves también se audita

---

6 · Siglas técnicas

Sigla	Desarrollo	Qué significa aquí
AES-256-GCM	*Advanced Encryption Standard, Galois/Counter Mode*	El cifrado del estado. GCM **autentica**: si alguien altera un byte, el descifrado falla
AEAD	*Authenticated Encryption with Associated Data*	La propiedad anterior, con su nombre formal
IV	*Initialization Vector*	12 bytes aleatorios, distintos en cada escritura
SHA-256	*Secure Hash Algorithm*	La huella de la cadena de auditoría y de los artefactos
CSP	*Content Security Policy*	La cabecera que impide que el panel cargue nada externo
CSRF	*Cross-Site Request Forgery*	Que otra web haga peticiones a tu panel. Lo impide `x-rootcause-request`
XSS	*Cross-Site Scripting*	Inyectar código en la página. Lo impiden `escapeHtml` y la CSP
CORS	*Cross-Origin Resource Sharing*	El permiso para que otro origen lea respuestas. **Aquí no se concede a nadie**
COOP / CORP	*Cross-Origin Opener/Resource Policy*	Aislamiento entre ventanas y recursos
RPC	*Remote Procedure Call*	Cómo se le pregunta algo a Bitcoin Core
PWA	*Progressive Web App*	El panel se puede instalar como aplicación
CI/CD	*Continuous Integration / Delivery*	Las comprobaciones y publicaciones automáticas
SAST	*Static Application Security Testing*	Análisis del código sin ejecutarlo. Aquí, CodeQL
CVE	*Common Vulnerabilities and Exposures*	Identificador estándar de una vulnerabilidad
ESM	*ECMAScript Modules*	El sistema de módulos con `import`, el que usa este proyecto
UUID	*Universally Unique Identifier*	Los identificadores generados por el servidor
ADR	*Architecture Decision Record*	Documento que registra una decisión y su porqué
HSM	*Hardware Security Module*	Dispositivo dedicado a custodiar claves. Este producto **no** lo sustituye
KDF	*Key Derivation Function*	Derivar una clave de una contraseña. **Aquí no se usa**: la clave se genera aleatoria
ACL	*Access Control List*	El control de permisos de Windows, que sustituye a los modos POSIX

7 · Términos del proyecto y de la familia RootCause

Término	Significado
RootCause	La familia de productos. La idea común: **encontrar el origen del problema, no solo el síntoma**

Término	Significado
«Diagnóstico primero. Intervención después.»	El lema. Explica por qué el producto detecta y explica, pero no actúa sobre los fondos
Familia RootCause	Cuatro repositorios hermanos: Windows Inspector, Web Inspector, Mobile Inspector y este
Skill `bitcoin-custody-audit`	Las 14 etapas de auditoría, empaquetadas como herramienta reutilizable
Las 14 etapas	La auditoría de custodia, en cuatro bloques: las claves, el software, la instalación y las personas
Las 12 capas	El criterio de auditoría de seguridad general del que este proyecto hereda su regla de honestidad
Bloque A / B / C / D	Cómo se agrupan las 14 etapas en el informe
Semáforo	[OK][ATENCION][FALLO][NO COMPROBADO], usado igual en todo el proyecto
`plugin/`	La copia distribuible de `.claude/`. **Generada, nunca editada a mano**

8 · Nombres que aparecen y conviene no confundir

Nombre	Qué es
COLDCARD	Hardware wallet de Coinkite. Protagonista del incidente de 2026 que originó el producto
Coinkite	El fabricante de COLDCARD. En `advisories.json` el `vendor` es `COLDCARD`, no `Coinkite`
Trezor	Otro fabricante. Su aviso en la matriz es de **filtración de datos de clientes**, no de defecto de claves
BitBox	Fabricante presente en el inventario de demostración
Bitcoin Core	La implementación de referencia del nodo. Es lo que este sistema consulta
Mk2, Mk3, Mk4, Mk5, Q	Modelos de COLDCARD que aparecen en los rangos de aviso
`standard` / `edge`	Los dos canales de firmware de COLDCARD. **Un aviso puede afectar a uno y no al otro**

9 · Frases del proyecto que resumen su criterio

Frase	Dónde aparece	Qué significa
«Diagnóstico primero. Intervención después.»	`README.md`	El producto detecta y explica; mover fondos es siempre una decisión humana
«Una etapa que no puede comprobarse sale omitida, nunca aprobada.»	Skill de auditoría	La regla de honestidad de todos los informes
«Un informe que no declara su cobertura es un informe que miente.»	`plugin/README.md`	Por qué cada script imprime una línea `COBERTURA`

Frase	Dónde aparece	Qué significa
«Un verde sobre avisos sin revisar es una tranquilidad falsa.»	Catálogo de reglas	Por qué existe `BTC-INTEL-001`
«Actualizar el firmware no repara la semilla existente.»	`BTC-KEY-001`	El malentendido más caro del dominio
«Una alerta sin siguiente paso entrena a ignorar alertas.»	`landing/reglas.html`	Por qué todo hallazgo trae remediación
«Dos copias de la misma verdad divergen.»	`generate-rule-docs.js`	Por qué la documentación se genera

---

Siguiente	
Resumen ejecutivo	`17-executive-summary.md`
Volver al índice	`README.md`